EU AI Act Compliance Audit Report

Automated pipeline output | Timestamp: 23/05/2026, 7.26.39

Assessment Metadata

• Session ID: session_default
• Compliance Score: 100/100
• Regulatory Status: FULLY COMPLIANT

1. Extracted Use-Case Facts (Source: Input Parser Agent)

Core Purpose: autonomous medical diagnostics platform
Target Sector: Healthcare / High-risk medical diagnostics
End Users: Clinical radiologists and hospital staff
Affected Persons: Patients undergoing diagnostic scanning
Deployment Context: Installed on hospital networks as an integrated clinical decision support tool.
Input Data Ingestion: Patient medical images (CT scans, X-rays, MRI), electronic health records (EHR) containing health data
Primary Outputs: Diagnostic classification reports, risk indicators, severity scoring, and anatomical annotations
GPAI Component Usage: None. Uses specialized clinical computer vision models.
Automation Level: High. Recommends diagnosis and classifications, but includes confirmation gates.
Human Oversight Claims: Clinical radiologists review, sign-off on every output, and can override any AI recommendation with an override button.
Potential Social Impact: Clinical decision outcomes, patient health status, medical diagnosis accuracy.

2. EU AI Act Path Classifications & Citations (Source: Decision Tree)

High-Risk AI System (Article 6.1 - Annex I Safety Component/Medical Device)

EU AI Act Flowchart Citations:

- Article 2 (Scope & Exclusions check - Determines if the system's deployment affects the EU market)
- Article 6.1 (High-Risk - Systems linked to Annex I safety components undergoing third-party checks)
- Articles 9-15 (High-Risk Requirements - Risk management, data governance, technical file, logging, human oversight)
- Article 26 (Deployer Obligations - Controls, monitoring, human oversight compliance for AI deployers)
- Article 99.4e (Fines - Specific penalty framework for Deployer non-compliance)
- Chapter IX (Post-Market Surveillance - Conformance framework for monitoring, info sharing, and market oversight)
- Article 99 (General Penalties and Fines framework - Outlines overall administrative enforcement)
- EU Legal Supremacy Disclaimer (The AI Act operates alongside, and does not replace, other sectoral EU laws)

3. Deduced Governance Observations (Source: Judge of Governance)

Human Oversight Framework: Human override button triggers manual lockouts, clinical review board oversees high-risk alerts.
Lifecycle Logging & Documentation: Full system logs, technical file architectures, and operating guidelines are provided.
System Transparency & Disclosures: Clear user-instructions manual, system capability bounds disclosed in product footer.
Risk Management Systems: Active risk management matrix updated bi-weekly, includes residual liability checks.
Continuous Monitoring & Drift: Continuous telemetry monitor registers sensor drifts and model accuracy.
Audit Logging Mechanisms: Automated append-only logging of inputs, inferences, and human overrides.
Organizational Accountability: Named AI compliance officer assigned; annual external safety audits scheduled.
Operational Role Clarity: Clinical operators defined as deployers; hospital network defined as provider/deployer.

4. Risk Boundaries: Assumptions & Gaps Checkers

Operational & Technical Assumptions Checked:

• Operational & Technical: The proposal for a "autonomous medical diagnostics platform" targeting Clinical radiologists and hospital staff assumes high-fidelity "Human-in-the-loop" oversight, claiming: "Clinical radiologists review, sign-off on every output, and can override any AI recommendation with an override button.". However, in real-world workflows, this creates a dangerous assumption that operators will actively review and verify the generated "Diagnostic classification reports, risk indicators, severity scoring, and anatomical annotations" before taking action. In high-throughput, resource-scarce environments, clinical or corporate operators are highly prone to "automation bias"—passively accepting or rubber-stamping recommendations without independent cognitive verification, effectively transforming an advisory tool into an autonomous pipeline.

• Supply Chain & Role: The deployment of a "autonomous medical diagnostics platform" within the Healthcare / High-risk medical diagnostics sector integrates upstream General Purpose AI (GPAI) capabilities, specifically: "None. Uses specialized clinical computer vision models.". The development team assumes this legal setup positions them purely as a "Deployer" who is exempt from developer-level safety liabilities. However, under Article 28 of the EU AI Act, because this GPAI foundation is integrated, fine-tuned, or modified to serve a domain-specific High-Risk application, this assumption is legally invalid. It risks reclassifying the developer as the primary "Provider", transferring full conformity assessment, audit logging, and risk management compliance burdens onto them.

• Legal Interpretation: The proposal for a "autonomous medical diagnostics platform" within the Healthcare / High-risk medical diagnostics assumes that clinical medical diagnostics is a standard helper application. However, under Annex III and Article 6, medical decision-support systems that analyze patient health data are designated as High-Risk or device-linked. The proposal assumes standard software compliance is sufficient, ignoring strict clinical validation, CE-marking coordination, and software-as-a-medical-device (SaMD) regulatory overlaps. Given the potential impact of "Clinical decision outcomes, patient health status, medical diagnosis accuracy.", a failure to preemptively align with statutory High-Risk obligations risks immediate market withdrawal or massive administrative fines.

• Vulnerability & Impact: The proposal for a "autonomous medical diagnostics platform" targeting "Patients undergoing diagnostic scanning" assumes that the system does not exploit human vulnerabilities or perpetuate structural inequalities. However, the system's impact on "Clinical decision outcomes, patient health status, medical diagnosis accuracy." creates an inherent power asymmetry. Under Article 5 of the EU AI Act, systems must not utilize subliminal, manipulative, or exploitative techniques. By deploying automated grading/analysis against "Patients undergoing diagnostic scanning", the system assumes that everyone has equal access and capability to challenge the algorithm, which is a high-risk assumption in real-world scenarios.

• Temporal & Lifecycle: Deploying the "autonomous medical diagnostics platform" in the context of "Installed on hospital networks as an integrated clinical decision support tool." assumes that compliance obligations only commence once the product is fully commercialized. However, the EU AI Act applies the moment a system is 'placed on the market' or 'put into service' (even for trial/pilot programs in "Installed on hospital networks as an integrated clinical decision support tool."). The proposal assumes its rollout is exempt under research/sandbox clauses, but any operational use with live data activates full legal liabilities immediately. Furthermore, any future model updates or weight adjustments in "Installed on hospital networks as an integrated clinical decision support tool." are assumed to be simple maintenance patches, whereas they actually constitute a 'substantial modification' requiring brand-new conformity certifications.

• Geographic & Jurisdictional: The deployment plan for "autonomous medical diagnostics platform" via "Installed on hospital networks as an integrated clinical decision support tool." assumes that geographic boundaries or external hosting provide a shield against EU regulatory jurisdiction. However, Article 2 of the AI Act establishes strict extraterritoriality: if the system's outputs are used or have effects within the European Union, the system is fully subject to the AI Act. This assumes that the location of the servers, developers, or operators in "Installed on hospital networks as an integrated clinical decision support tool." exempts the project, which is a major legal liability if EU residents are affected.

• Data Provenance: The proposal for a "autonomous medical diagnostics platform" assumes that its input datasets ("Patient medical images (CT scans, X-rays, MRI), electronic health records (EHR) containing health data") are inherently balanced, high-quality, and legally compliant for processing. However, training or running models on "Patient medical images (CT scans, X-rays, MRI), electronic health records (EHR) containing health data" assumes the absence of systemic or historical biases. In practice, this data frequently reflects entrenched patterns that, when processed, mathematically codify and perpetuate bias. This violates Article 10's strict data governance requirements, especially considering the system's potential impact on "Clinical decision outcomes, patient health status, medical diagnosis accuracy.".

Identified Regulatory Assessment Gaps:

Ø<ß‰ No active compliance omissions or gaps detected. Perfect structural compliance achieved!

5. Confidence Prevention & Auditing Queries (Prevention of Confidence Agent)

AI Compliance Expert Auditing Queries:

1. **Under high-throughput clinical pressures, radiologists are statistically highly susceptible to 'automation bias'. What specific interface controls or confirmation gates prevent clinical sign-off from becoming a passive, rubber-stamped review rather than active ocular verification?**

2. **Since medical computer vision model performance degrades significantly on scanner variations and calibration drift (e.g., Siemens vs. GE scanner raw outputs), what real-time drift-detection telemetry is implemented to flag accuracy drops before diagnostic anomalies occur?**

3. **Given that diagnostic reports and anatomical overlays process highly protected healthcare and health-category data under EU definitions, what legal and technical measures are deployed at the ingestion layer to guarantee absolute data minimization and GDPR/HIPAA-compliant containment?**

binding certification under the EU AI Act.